



INGENIERÍA DE CIBERSEGURIDAD · CURSO CBH01 · UNI

Programa Integral de Defensa contra Ingeniería Social

Con énfasis en phishing — Caso: TeleConecta Perú S.A.C. (empresa ficticia)

Carlos Henry Santana Palomino

Código 20230348C · Sección M

Docente: Carlos Enrique Miranda Quezada · Ciclo 2026-I

Agenda

Recorrido del programa: de la exposición al riesgo hasta la defensa medible

01

Resumen ejecutivo y exposición encontrada



02

Cómo nos ve un atacante desde afuera



03

Tres escenarios de ataque modelados y simulados



04

Vulnerabilidades humanas y análisis de riesgos



05

Programa de defensa: técnico, humano,
organizacional



06

Capacitación, estándares y hoja de ruta



Resumen ejecutivo: tres riesgos concentran la severidad

El factor humano —no la infraestructura técnica— es la superficie de ataque predominante en TeleConecta.



1

PRIORIDAD MÁXIMA

Fraude financiero por voz clonada, suplantando al Gerente General

Impacto crítico e irreversible. No existe un protocolo de doble confirmación para pagos urgentes.



2

IMPACTO ALTO

Acceso a sistemas críticos mediante una llamada fraudulenta dirigida

Acceso a la red interna y a sistemas de monitoreo, usando contraseñas ya filtradas.



3

PROBABILIDAD ALTA

Robo masivo de contraseñas mediante correos falsos

Mayor probabilidad confirmada empíricamente en la simulación.

Nivel de exposición encontrado

Resultado de la simulación de phishing masivo — muestra de 30 colaboradores en entorno controlado y seguro

72.4%

hizo clic en el enlace malicioso

55.2%

entregó su usuario y contraseña

24.1%

reportó el correo sospechoso

< 1 día

para que un atacante reconstruya
nuestro organigrama, gratis



Hallazgo contraintuitivo

El grupo Técnico —el que mejor conoce la infraestructura— tuvo una tasa de clics superior (85.7%) frente al grupo Administrativo (68.2%). Mayor conocimiento técnico no equivale a mayor cautela ante un pretexto de urgencia relacionado con sus propias herramientas de trabajo.

Qué puede saber un atacante de nosotros, sin hackear nada

Toda esta información se consiguió gratis, en internet, sin tocar un solo sistema de la empresa



Mapa de la red

Se identificó qué plataforma de correo usamos y un sistema interno de monitoreo visible desde internet



Organigrama de la empresa

En menos de un minuto se reconstruyó el organigrama completo: nombres, cargos y jerarquía



Patrón de correos

Se dedujo el formato exacto del correo corporativo de cualquier colaborador



Contraseñas filtradas

El responsable de la red crítica tiene contraseñas suyas ya expuestas en internet



Sistema crítico expuesto

El panel de monitoreo de red está accesible desde internet, sin ninguna protección adicional



Vista integrada del riesgo

Toda esta información se conecta fácilmente para construir el perfil ideal de una víctima

Tres escenarios de ataque modelados

Cada uno explota una debilidad humana distinta, dirigido a un colaborador clave de la empresa



ESCENARIO 1

Phishing masivo

OBJETIVO

Robo de contraseñas corporativas

A QUIÉN AFECTA

30 empleados (muestra)

POR QUÉ FUNCIONA

Urgencia, autoridad institucional

MÉTODO

Correo falso masivo



ESCENARIO 2

Llamada fraudulenta dirigida

OBJETIVO

Acceso a la red interna crítica

A QUIÉN AFECTA

Marco Villanueva (Red interna)

POR QUÉ FUNCIONA

Confianza ganada con datos reales

MÉTODO

Llamada telefónica + mensaje de texto



ESCENARIO 3

Deepfake de voz

OBJETIVO

Fraude financiero (suplanta al Gerente General)

A QUIÉN AFECTA

Valeria Ccopa (Asist. Gerencia)

POR QUÉ FUNCIONA

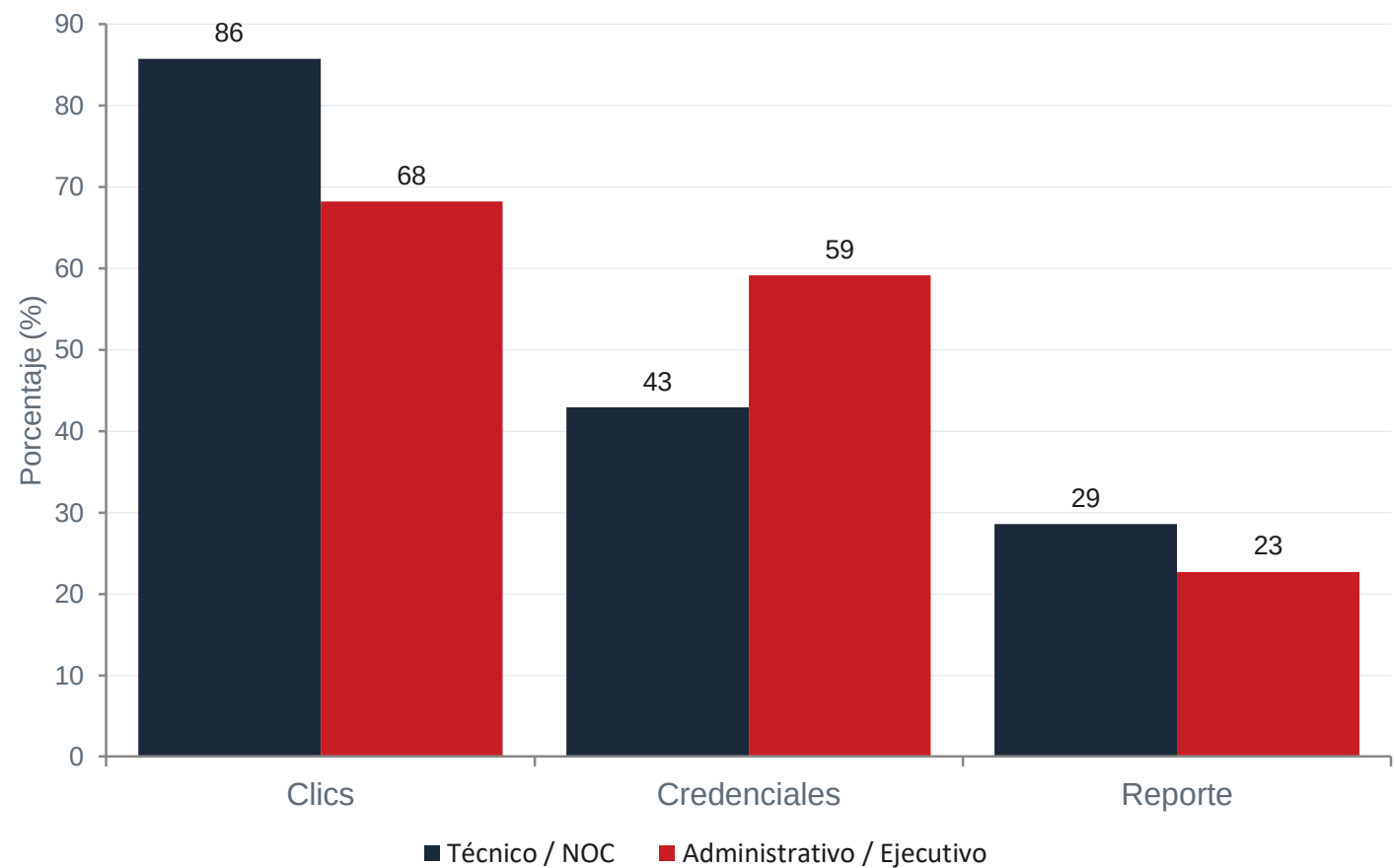
Autoridad, urgencia y secreto

MÉTODO

Voz clonada por IA + llamada de WhatsApp

Resultados de la campaña de phishing simulada

Escenario 1 — segmentado por grupo, en un entorno de prueba controlado y seguro



Lectura clave

- El grupo técnico clickea más, pero también reporta más — mayor familiaridad con los sistemas, no necesariamente más cautela.
- El grupo administrativo, aunque clickea menos, convierte más a contraseñas entregadas: menor capacidad de detectar señales de alerta dentro de la página falsa.
- Marco Villanueva (colaborador de alto riesgo) se detuvo en el clic sin entregar contraseñas — pero permanece vulnerable a una llamada fraudulenta más elaborada (Escenario 2).

Por qué la gente cae en estos engaños

Ningún escenario depende de un único truco psicológico — se combinan a propósito según a quién se ataca



Autoridad

Suplantación de Soporte,
Gerencia de TI y el Gerente
General



Urgencia / escasez

Plazos del mismo día en los tres
escenarios



Confianza con datos reales

Mencionar datos reales y
verificables de la víctima para
ganar su confianza



Familiaridad inmediata

Pretexto ligado a herramientas
de uso diario del personal
técnico

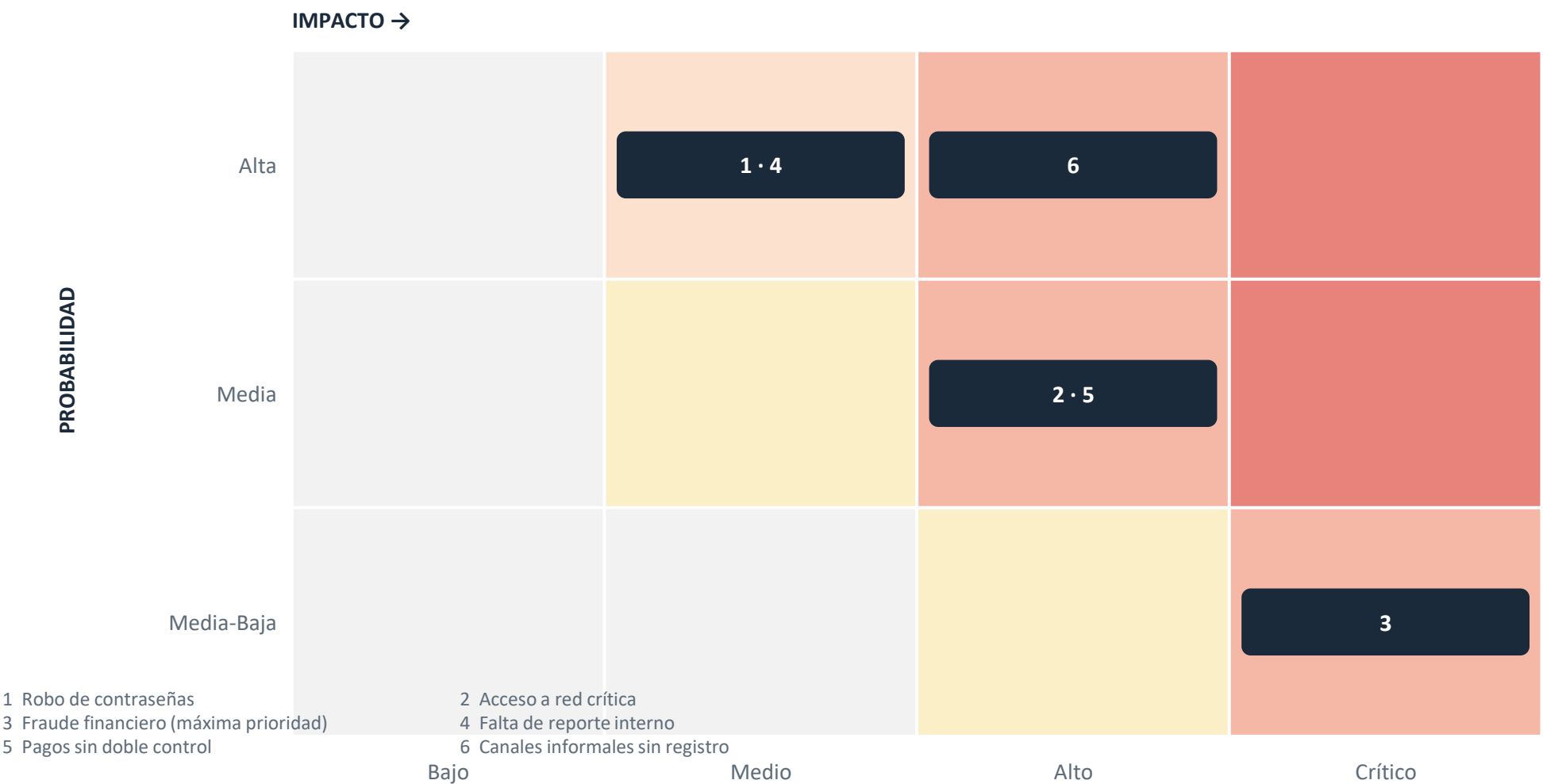


Aislamiento social

Solicitud explícita de discreción
ante el resto del equipo

Mapa de riesgos: qué tan probable y qué tan grave

Los seis riesgos identificados se concentran en las zonas de mayor severidad



Programa de defensa en profundidad

Ningún riesgo se cierra con un control aislado: tres capas complementarias envuelven los activos críticos



Técnicos

- Verificación de correos auténticos
- Doble verificación de identidad
- Filtro inteligente de correo
- Acceso restringido a sistemas críticos

Reduce el robo de contraseñas y accesos indebidos



Humanos

- Capacitación segmentada
- Simulaciones trimestrales
- Canal de reporte no punitivo

Reduce el error humano en los tres escenarios



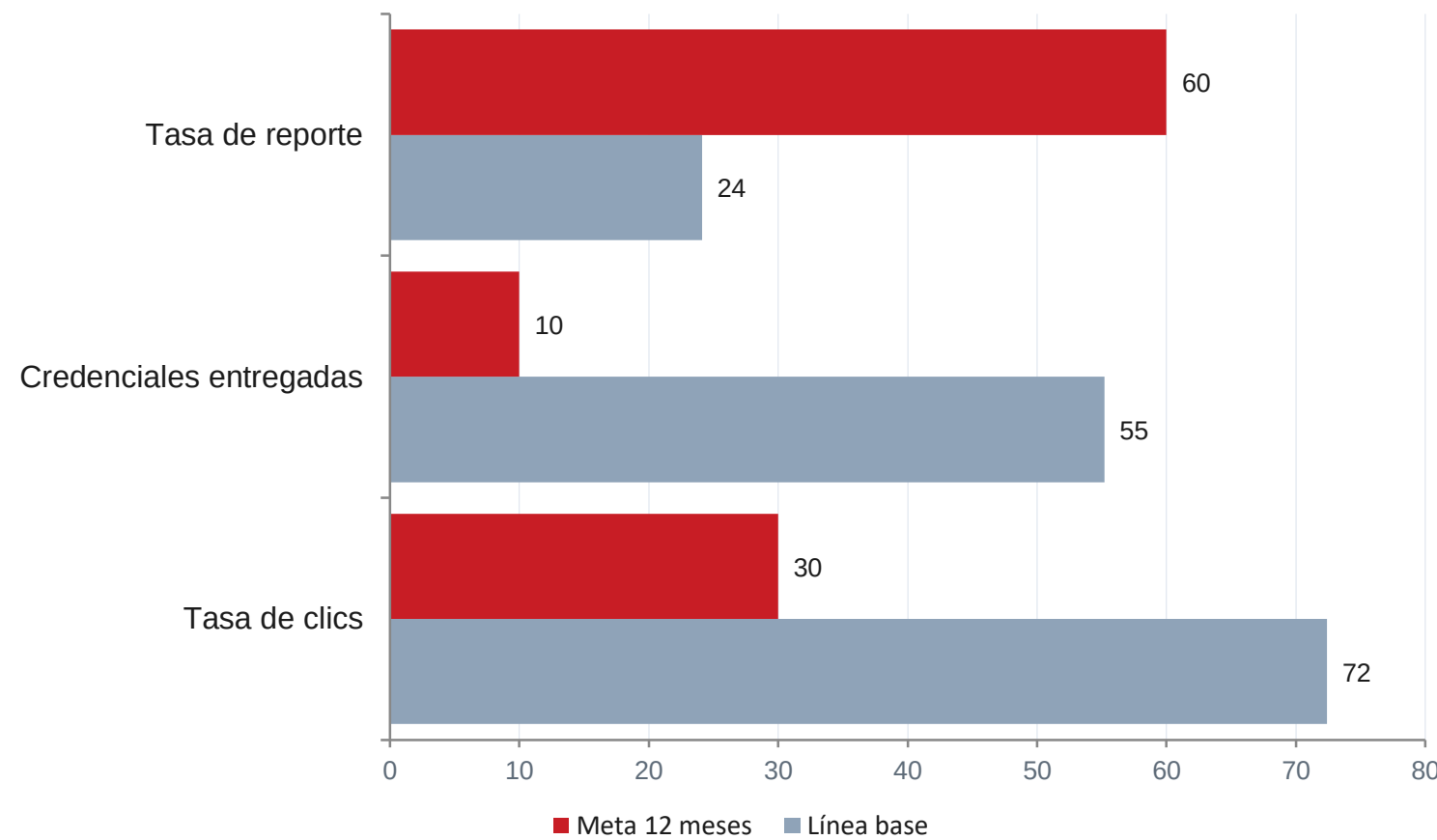
Organizacionales

- Doble confirmación antes de pagar
- Segregación de funciones en pagos
- Política de comunicación oficial
- Gestión de incidentes

Cierra las brechas de proceso y control interno

Programa de Capacitación: metas a 12 meses

Capacitación trimestral segmentada por perfil (técnico, administrativo, ejecutivo)



Plan anual (4 trimestres)

- Q1 — Fundamentos + canal de reporte (todo el personal)
- Q2 — Llamadas fraudulentas y protección de sistemas críticos (equipo técnico)
- Q3 — Doble confirmación antes de pagar (Ejecutivo/Mando medio)
- Q4 — Refuerzo + segunda simulación comparativa

Un programa alineado a estándares internacionales

No son decisiones improvisadas: cada medida sigue prácticas reconocidas mundialmente, y facilita futuras auditorías o certificaciones



Gestión de riesgo

Cubre el ciclo completo: gobernar, prevenir, detectar, responder y recuperar — no solo prevención



Certificación de seguridad

El estándar de certificación más reconocido a nivel mundial en gestión de seguridad de la información



Catálogo de amenazas

Base de conocimiento usada por la industria para catalogar y anticipar tácticas de atacantes reales

Hallazgo clave: el fraude con voz clonada por IA es una amenaza tan nueva que la industria aún no tiene una forma madura de detectarla automáticamente. Por eso, los controles organizacionales —no la tecnología— siguen siendo hoy nuestra mejor defensa ante este riesgo.

Roadmap de seguridad

Priorizado según severidad de riesgo y recursos realistas de una PYME de 200 empleados





Conclusiones

- ✓ TeleConecta presenta un nivel de madurez medio-bajo: infraestructura técnica razonable, pero sin un área de seguridad independiente del equipo de TI.
- ✓ La vulnerabilidad humana no es uniforme: el personal técnico clickea más, el administrativo entrega más credenciales — el programa debe segmentarse.
- ✓ El riesgo de mayor impacto —el fraude por voz clonada— no depende de vulnerar ningún sistema, sino de la ausencia de un protocolo de doble confirmación antes de pagar.
- ✓ Los controles organizacionales, independientes de la tecnología del atacante, serán más resilientes en el tiempo frente a la IA generativa que los controles técnicos puntuales.